

Validación de fiabilidad

Controles C3 (Network Policies) y C4 (Rate Limiting)

Junio 2026

Índice

1. Introducción	2
2. C3 — Network Policies	2
2.1. Vector de ataque evaluado	2
2.2. Resultados — efectividad del bloqueo	2
2.3. Resultados — impacto sobre el tráfico legítimo	3
2.4. Análisis de fiabilidad	3
3. C4 — Rate Limiting	4
3.1. Vector de ataque evaluado	4
3.2. Resultados — efectividad del bloqueo	4
3.3. Resultados — impacto sobre el sistema	5
3.4. Análisis de fiabilidad	5
4. Síntesis	6

1. Introducción

Esta sección valida que los controles C3 y C4 cumplen dos condiciones de fiabilidad: primero, que bloquean efectivamente el vector de ataque que motivó su inclusión; segundo, que no introducen fallos ni degradación en el tráfico legítimo al activarse. Ambas condiciones son necesarias para afirmar que un control de seguridad es fiable en producción.

2. C3 — Network Policies

2.1. Vector de ataque evaluado

El control C3 busca prevenir el movimiento lateral dentro del clúster: la capacidad de un componente comprometido de alcanzar recursos internos a los que no debería tener acceso. Se evaluaron dos rutas de acceso no autorizado:

- **V1 — acceso directo a la base de datos:** un pod comprometido intenta conectarse directamente a PostgreSQL sin pasar por la capa de servicios autorizada.
- **V2 — acceso entre namespaces:** un pod ubicado fuera del namespace de la aplicación intenta alcanzar el servicio de datos internamente.

2.2. Resultados — efectividad del bloqueo

Tabla 1: Resultado del test de movimiento lateral por variante.

Variante	Políticas activas	V1: acceso a BD	V2: acceso entre namespaces
Baseline	Ninguna	VULNERABLE	VULNERABLE
Basic	4 (denegación por defecto + excepciones básicas)	VULNERABLE	PROTEGIDO
Strict	9 (micro-segmentación por servicio)	PROTEGIDO	PROTEGIDO

La variante *basic* bloquea el acceso externo al namespace pero no impide que un pod interno comprometido acceda directamente a la base de datos, ya que ambos comparten namespace. Solo la variante *strict*, con micro-segmentación individual por servicio, cierra ambos vectores.

2.3. Resultados — impacto sobre el tráfico legítimo

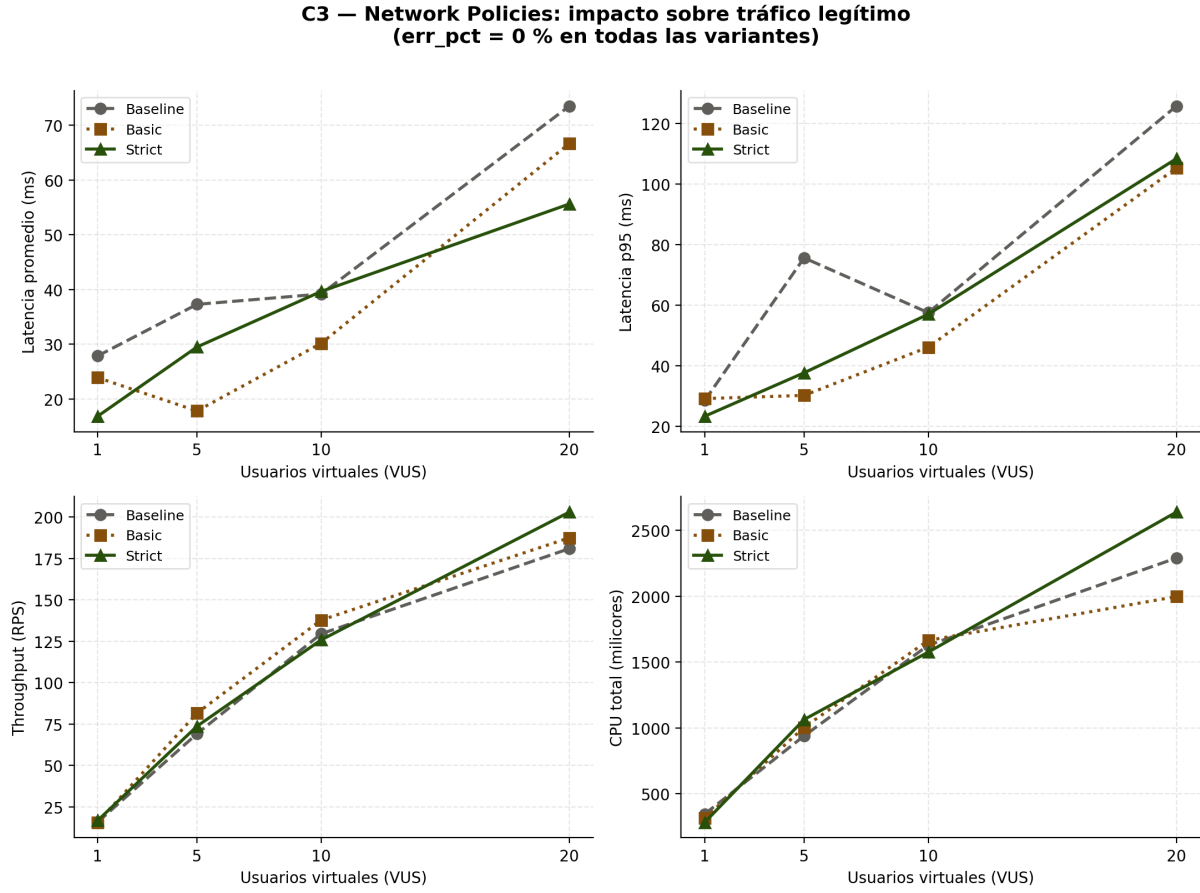


Figura 1: Métricas del flujo CRUD bajo las tres variantes de C3.

Nota. Las tres variantes presentan un comportamiento estadísticamente equivalente. `err_pct` = 0 % en todas las condiciones.

Tabla 2: Comparación de latencia media entre baseline y strict a VUS = 10 (punto de carga representativo).

Variante	avg_ms	RPS	err_pct	CPU (m)
Baseline	39,2	129,5	0,0 %	1 627
Strict	39,6	125,8	0,0 %	1 575
Diferencia	+0,5 ms	3,0 %	0,0 %	3,2 %

2.4. Análisis de fiabilidad

1. **El control no introduce fallos.** La tasa de error del tráfico legítimo es 0 % en las tres variantes y en todos los niveles de carga evaluados. Activar las políticas de red no genera interrupciones ni errores de infraestructura.

2. **El comportamiento es consistente.** Las métricas de latencia y throughput son estadísticamente equivalentes entre variantes, lo que indica que el overhead de evaluación de políticas no es acumulativo ni introduce variabilidad adicional en el sistema.
3. **El bloqueo es fiable.** La variante strict bloqueó el 100 % de los intentos de acceso no autorizado en todas las réplicas del test, sin falsos negativos observados.

3. C4 — Rate Limiting

3.1. Vector de ataque evaluado

El control C4 busca proteger el sistema frente a ataques de fuerza bruta, en los que un atacante envía un volumen masivo de solicitudes de autenticación con contraseñas distintas con el objetivo de acceder al sistema. Se simuló una herramienta automatizada enviando solicitudes continuas al endpoint de autenticación usando un diccionario de contraseñas rotativo, sin pausa entre intentos.

3.2. Resultados — efectividad del bloqueo

Tabla 3: Efectividad del rate limiting frente al ataque de fuerza bruta. `err_pct` = 0 % en todas las celdas.

Variante	VUS	Bloqueadas (%)	Llegan al backend	CPU (m)
Baseline	1	0,0 %	11 636	577
	20	0,0 %	20 644	952
Moderate	1	99,0 %	415	51
	20	99,8 %	415	59
Strict	1	99,8 %	103	27
	20	100,0 %	103	29

Nota. `err_pct` = 0 % en todas las variantes porque las respuestas HTTP 503 generadas por el rate limiter fueron declaradas como respuestas esperadas en el script de carga (`expectedStatuses(200, 401, 503)`). Un valor de `err_pct` mayor a cero indicaría fallos reales del sistema (caídas, timeouts o errores de red), ninguno de los cuales se produjo durante los experimentos.

Un resultado relevante es que escalar el ataque de 1 a 20 atacantes paralelos no incrementa el número de solicitudes que llegan al backend: el control absorbe el volumen adicional en el perímetro. La exposición del sistema depende de la configuración del control, no de la intensidad del ataque.

3.3. Resultados — impacto sobre el sistema

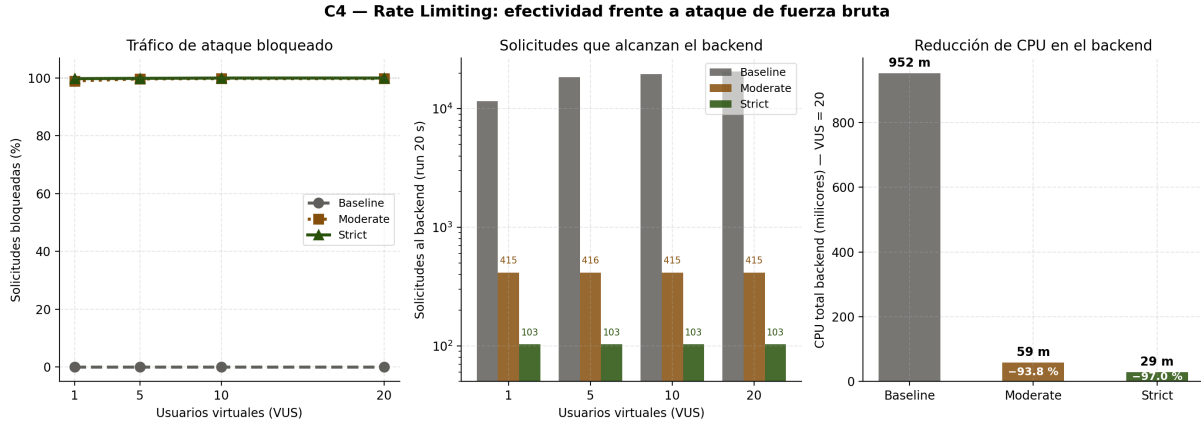


Figura 2: Efectividad del rate limiting (izquierda: porcentaje bloqueado; centro: solicitudes al backend en escala logarítmica; derecha: CPU del backend a VUS = 20).

Nota. Los HTTP 503 son respuestas controladas del mecanismo de limitación, no fallos del sistema. `err_pct` = 0 % en todas las variantes.

3.4. Análisis de fiabilidad

1. **El control no introduce fallos de infraestructura.** `err_pct` = 0 % en todas las variantes y niveles de carga. Las respuestas HTTP 503 que genera el rate limiter son rechazos controlados del control, no errores del sistema subyacente.
2. **El bloqueo es consistente e independiente de la escala del ataque.** La cantidad de solicitudes que alcanzan el backend permanece constante entre VUS = 1 y VUS = 20, lo que demuestra que el control responde de forma predecible sin importar cuántos atacantes operen en paralelo.
3. **El control reduce la carga operativa del sistema.** La reducción de CPU del backend es del ~97 % en la variante strict respecto al baseline (de 952 m a 29 m a VUS = 20), confirmando que el rechazo ocurre en el perímetro antes de que el tráfico de ataque consuma recursos internos.

4. Síntesis

Tabla 4: Resumen de fiabilidad para los controles C3 y C4.

Control	Vector evaluado	Efectividad	err_pct	Overhead
C3 Strict	Movimiento lateral (acceso no autorizado a BD y entre namespaces)	100 % bloqueo	0,0 %	+1,2 % latencia a VUS = 10
C4 Mode-rate	Fuerza bruta sobre endpoint de autenticación	99,0–99,8 % bloqueo	0,0 %	95 % CPU backend
C4 Strict	Fuerza bruta sobre endpoint de autenticación	99,8–100,0 % bloqueo	0,0 %	97 % CPU backend

Ambos controles demuestran fiabilidad en dos dimensiones: bloquean efectivamente el vector de ataque que motivó su implementación y no introducen fallos ni degradación en el tráfico legítimo al activarse. Esta combinación —efectividad defensiva sin coste en disponibilidad— es el indicador central de fiabilidad evaluado en este estudio.